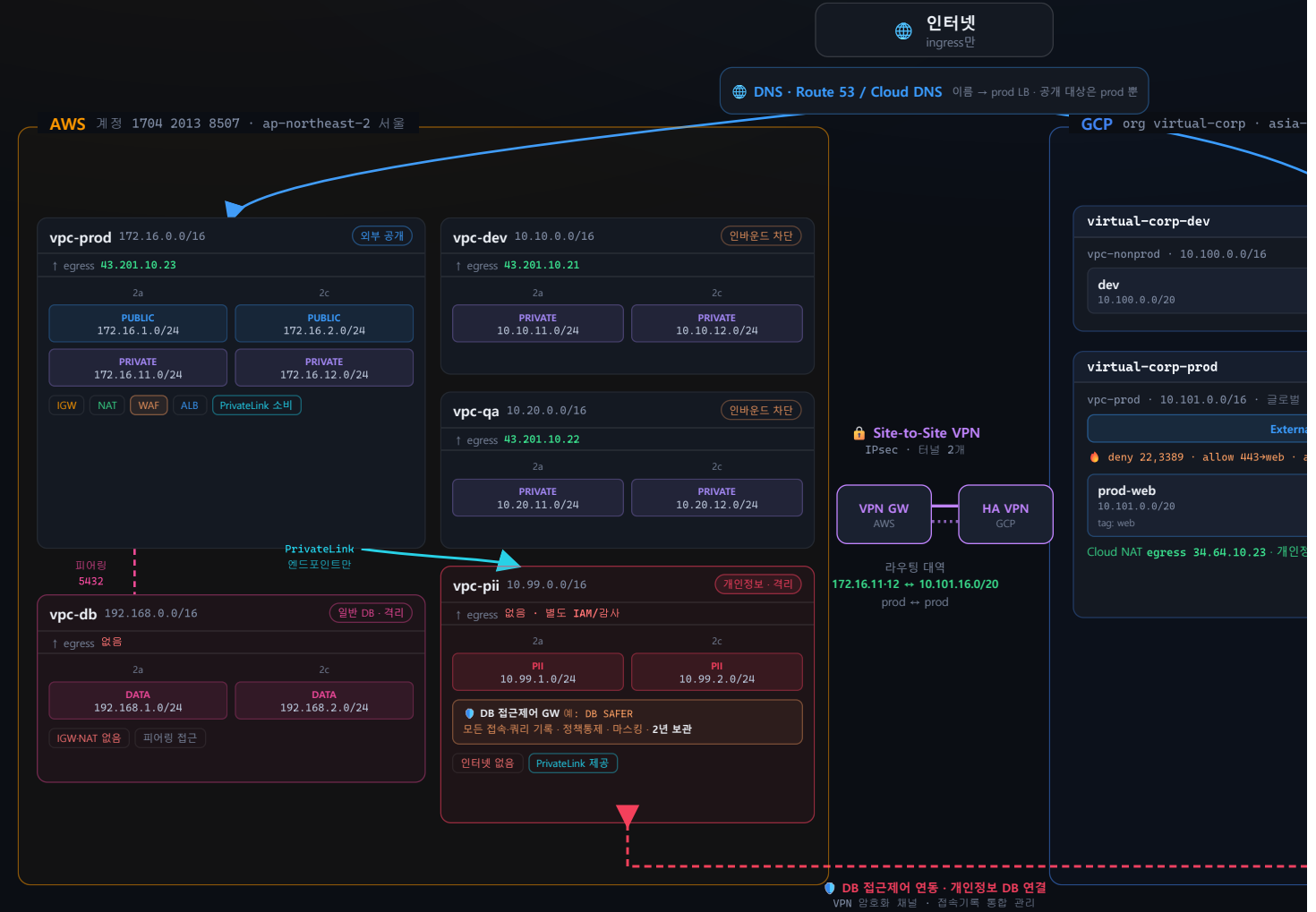


가상 회사 멀티클라우드 아키텍처

AWS · GCP 두 환경 · Site-to-Site VPN · DNS/WAF 진입 · **개인정보 DB 격리(PrivateLink / PSC)** · 공통 보안 계층(IAM · 로깅 · KMS)



🔑 신원 · 접근통제 (IAM)

AWS IAM Identity Center(SSO) · 역할 기반 · MFA 필수

GCP Cloud IAM · 역할 기반 · MFA 필수

연동 IAM ↔ Workload Identity · 장기 키 없이 단기 토큰

개인정보 DB 접근 역할 분리 · 승인 기반 임시 권한 · 접근 시 기록

📁 중앙 로깅 · SIEM

AWS CloudTrail · VPC Flow Logs · ALB 로그 · DB SAFER

GCP Audit Logs · VPC Flow Logs · LB 로그 · DB SAFER

한 곳에 모음(불변·암호화) → SIEM 이상행위 탐지 · 보관 PII 2년 / 일반 1년

개인정보 DB 격리 — 왜 이렇게

별도 경계 + 엔드포인트 + DB 접근제어. 네트워크를 통째로 잇는 피어링이 아니라, DB 서비스 하나만 엔드포인트로 내주고 그 앞에 접근제어 게이트웨이를 둔다.

· AWS — 별도 vpc-pii + PrivateLink + DB 접근제어 GW

· GCP — 별도 virtual-corp-pii + PSC + DB 접근제어 GW

· 접근제어 GW 예시 — **DB SAFER** (모든 접속 쿼리 기록 · 정책통제 · 마스크)

개인정보보호법 안전성 확보조치 — 개인정보처리시스템 접속기록 **2년 이상 보관**(고유식별·민감정보 또는 5만명 이상). ISMS-P 접근 통제·접근기록 요건에 대응.

🚨 **긴급 접속 절차** — DB SAFER 장애 시 → 클라우드 콘솔 직접 접속 (CloudTrail / Audit Logs로 별도 기록, 사후 감사 대상)

AWS · GCP 개념 대응

네트워크 범위 VPC = 리전

환경 분리 계정 하나 · VPC 하나

방화벽 SG + NACL

개인정보 DB PrivateLink

두 클라우드 연결 Site-to-Site

